

Roadmap

SecureGate is finished: it was built for Microsoft Innovate 2026 (Problem Statement 24), and it is not actively maintained. This page lists what was planned or wished for but **never built**, so that anyone who picks the project up knows where to start. Nothing on this page exists in the code; everything on the other pages does.

There were no open GitHub issues at the close-out, so the ideas are kept here instead.

Planned and approved, not built

Live checks for ACME Pay, and policy rule 2. ACME Pay, the payment provider invented for the demos, would become a small web service on Azure that issues and revokes `acme_live_` keys. SecureGate and TruffleHog would ask it whether a key they found still works, so the demos could show "verified live" and "revoked" without any real credential. A new **rule 2** would then let a pull request pass, marked **resolved**, once the leaked key is revoked *and* gone from every file of the newest commit. The plan was approved and is kept as it was: Live checks (`docs/history/plan-live-checks-not-built.md` in the repository). Today, ACME Pay tokens always show "Not checked" or "Unverified" (see Limitations (`limitations.pdf`)).

The rest of the policy table. `policy.yaml` uses rules 1, 3, 7, 8, 9, 10, 13 and 14 of SecureGate's 14-rule policy table. Rule 2 is the one above; rules 4, 5, 6, 11 and 12 were kept for later and never designed. Their numbers stay free, so that reports keep naming each rule by its number in the table.

Clearer names for the commands. The `make` commands were meant to get clearer, friendlier names, with a printable page about them. They were not renamed. Getting started (`getting-started.pdf`) lists every command as it is. A rename has to change the `Makefile`, `Start SecureGate.cmd`, the menu, their tests (`tests/test_menu.py` and `tests/test_launcher.py` fail when a command no longer exists) and every page that quotes a command.

Ideas, from the limitations

Each of these answers a point in Limitations (`limitations.pdf`).

- **Catch the last miss of the scorecard.** With all four scanners, a password inside a `Dockerfile` is still missed, and an AWS secret key next to its key id gets a warning instead of a block. Both show in the scorecard of `make test` (Testing (`testing.pdf`)).
- **The same fingerprint for the same secret on GitHub.** The merge gate makes a new fingerprint key on every run. SecureGate already reads a key from the environment variable `SECUREGATE_HMAC_KEY`; the workflow and the action would only need to pass it from a repository secret.
- **A required review of the gate's own files.** `.github/CODEOWNERS` names who reviews changes to the workflow and the rules. Making that review required needs a second maintainer, because nobody can approve their own pull request.
- **Semgrep and Bandit pinned by checksum.** They are installed at exact versions, but the packages they depend on can change. A requirements file with hashes would pin those too.
- **A comment for pull requests from forks.** GitHub gives them a read-only token, so SecureGate cannot comment. A second workflow, started when the check finishes, could post the comment with its own token.

- **A scheduled sweep.** Both gates look at new changes. Nothing scans every branch's whole history on a schedule, for example every night, with `securegate scan . --mode repo --scanners all`. The action judges pull requests only, so a sweep would be a second workflow, run on a schedule and by hand.
- **The launcher on macOS and Linux.** Start `SecureGate.cmd` is for Windows. Elsewhere, `make menu` opens the same menu from a terminal.